

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|--------------------------|-------------------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☒	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional):

Recommendations to IT Manager / Stakeholders

Implement Least Privilege and Separation of Duties — Currently all employees have access to sensitive customer and credit card data. Access should be restricted so employees only access data necessary for their role, reducing insider threat risk and improving PCI DSS and SOC compliance.

Establish Encryption — No encryption is currently in place for stored or transmitted data. Encryption must be implemented immediately for all sensitive customer and credit card data to meet PCI DSS and GDPR requirements.

Strengthen Password Policies and Implement a Password Management System —

Current password requirements are weak. Strong password policies and a centralized password management system should be enforced to protect against unauthorized access and meet PCI DSS standards.

Create a Disaster Recovery Plan —

No disaster recovery plan exists. A formal plan must be developed to ensure business continuity in the event of a system failure, cyberattack, or natural disaster.

Set Up Regular Backups —

There are currently no backups in place. Automated and regular data backups should be implemented to prevent permanent data loss during incidents.

Install an Intrusion Detection System (IDS) —

No IDS exists to monitor for active threats. Installing an IDS will allow the IT team to detect and respond to suspicious network activity before it causes serious damage.

Create a Monitoring and Maintenance Schedule for Legacy Systems —

Legacy systems are not being regularly monitored or maintained. A clear schedule and assigned responsibility should be established to reduce vulnerabilities in outdated systems.

Classify and Inventory All Data Assets —

Data is not properly classified or inventoried. A full data classification system should be created, especially for EU customer data, to meet GDPR requirements and improve overall data management.

Restrict Access to Credit Card Information —

Only authorized payment-processing staff should have access to customers' credit card data. This is a direct PCI DSS requirement and significantly reduces the risk of financial data exposure.

Enforce and Document Privacy Policies for EU Customers —

While a 72-hour breach notification plan exists, data privacy policies need to be fully enforced and documented

across the organization to maintain full GDPR compliance and protect EU customer data.